INSTITUTO FEDERAL
Acre

Curso Superior de Tecnologia em Sistemas para Internet
Disciplina: Governança de Tecnologia da Informação
Turma: CSTSI 6 – 2026.2
Equipe 03

Euzébio Nascimento Oliveira Neto
Pedro Sales da Costa Araújo
Ricardo Costa da Silva

MATRIZ DE RISCOS DE TI
PREFEITURA DE BOA ESPERANÇA

Rio Branco – AC
2026

1 IDENTIFICAÇÃO

Grupo: Euzébio, Pedro e Ricardo (Equipe 03).
Organização analisada: Prefeitura Municipal de Boa Esperança — mesmo cenário da Matriz Inicial do Plano Diretor de Tecnologia da Informação (PDTI) de 26/08/2026.
Síntese do cenário: 82 mil habitantes; 12 escolas, 4 unidades de saúde, 1 hospital e 1 Centro de Referência de Assistência Social (CRAS). São 1.150 servidores, 420 deles usuários diários de sistemas. A equipe de Tecnologia da Informação (TI) tem 5 servidores efetivos e 2 terceirizados. O orçamento para novas iniciativas é de R$ 480 mil, com 23 contratos de tecnologia. Os sistemas essenciais são protocolo, folha, compras, arrecadação, prontuário, matrícula e portal. Não existe Comitê de Governança de TI formalizado.
Restrições consideradas: saúde e folha de pagamento são prioridades institucionais; integração, segurança, custo e manutenção devem ser avaliados antes de contratar; iniciativas de alto custo exigem aprovação do Gabinete e da Secretaria de Administração; o primeiro ciclo deve gerar resultados observáveis em até 12 meses.

2 ESCALA DE AVALIAÇÃO

Probabilidade e impacto receberam notas de 1 (muito baixo) a 5 (muito alto). **Índice de risco = Probabilidade × Impacto.** As faixas de prioridade do índice estão no Quadro 1.

Quadro 1 – Faixas de prioridade do índice de risco

Índice	**Prioridade**
1 a 5	Baixo
6 a 12	Médio
13 a 19	Alto
20 a 25	Crítico

Fonte: elaborado pelos autores (2026).

Faixas conforme o material da aula de 30/09/2026. Na probabilidade, nota 5 indica evento que já ocorre repetidamente e nota 4, evento provável no cenário atual. Em caso de empate no índice, desempatou-se pela restrição institucional: vêm primeiro os riscos que atingem saúde ou folha, diretamente ou por desencadear outro risco que as atinja.

3 MATRIZ DE RISCOS

Foram identificados quatro riscos, todos ligados a ativos ou serviços do diagnóstico, descritos no Quadro 2. A ordem de prioridade está na seção 4.

Quadro 2 – Matriz de riscos de TI da Prefeitura de Boa Esperança

Risco	Ativo ou serviço	Evento de risco	Causa	Consequência
R1	Dados da folha de pagamento e do prontuário (rotina de backup)	Após uma falha de servidor, exclusão acidental ou ataque, a restauração do backup falhar e os dados não puderem ser recuperados, total ou parcialmente.	Backup parcialmente manual; não há teste mensal de restauração; o último teste foi há 11 meses.	Atraso ou erro no pagamento de 1.150 servidores; perda do histórico clínico de pacientes; exposição a sanções da Lei Geral de Proteção de Dados Pessoais (LGPD); retrabalho para recompor dados.
R2	Sistema de prontuário (4 unidades de saúde e hospital)	O prontuário ficar lento ou fora do ar durante o atendimento, obrigando as unidades a atrasar consultas ou registrar em papel.	Causa raiz não identificada (pode estar na rede, no servidor ou no fornecedor); ausência de monitoramento de desempenho; ausência de Acordo de Nível de Serviço (SLA); chamados tratados apenas caso a caso, sem análise do problema de fundo.	Filas e atraso no atendimento; registros incompletos do paciente; risco à segurança do paciente; sobrecarga da TI com chamados repetidos.
R3	Estações de trabalho (14 computadores sem atualizações de segurança)	Um malware ou ransomware explorar uma vulnerabilidade não corrigida em um desses computadores e se espalhar pela rede da Prefeitura.	14 computadores não recebem atualizações de segurança; 38 computadores têm mais de 7 anos.	Paralisação de setores; criptografia ou vazamento de dados pessoais; se combinado ao R1, perda de dados sem recuperação.
R4	Portal da Prefeitura (serviços ao cidadão)	O portal ficar indisponível por várias horas novamente, impedindo o cidadão de acessar serviços e informações.	Não há SLA nem procedimento de continuidade; a causa da queda de 19 horas do último mês não foi identificada.	Cidadãos sem acesso (cerca de 4.000 acessos/mês); aumento do atendimento presencial; prejuízo à transparência pública e à imagem da Prefeitura.

Fonte: elaborado pelos autores (2026).

4 AVALIAÇÃO DO RISCO

Dois riscos são críticos (R2, índice 25, e R1, índice 20) e dois são médios (R3 e R4, índice 12). O Quadro 3 está em ordem de prioridade.

Quadro 3 – Avaliação e prioridade dos riscos

Risco	Probabilidade	Impacto	Índice	Prioridade
R2 – Lentidão/queda do prontuário	5 (Muito alta)	5 (Muito alto)	5 × 5 = 25	Crítico – 1º
R1 – Falha na restauração de dados	4 (Alta)	5 (Muito alto)	4 × 5 = 20	Crítico – 2º
R3 – Malware via computadores desatualizados	3 (Média)	4 (Alto)	3 × 4 = 12	Médio – 3º
R4 – Indisponibilidade do portal	4 (Alta)	3 (Médio)	4 × 3 = 12	Médio – 4º

Fonte: elaborado pelos autores (2026).

5 JUSTIFICATIVA DAS NOTAS E DA PRIORIDADE

5.1 R1 – FALHA NA RESTAURAÇÃO DE DADOS (ÍNDICE 20)

Probabilidade 4: evento provável no cenário atual. Parte do backup depende de ação manual e não há teste mensal; sem teste há 11 meses, não há garantia de que as cópias sejam recuperáveis. Não há registro de perda até agora.

Impacto 5: atinge folha e saúde, as duas prioridades institucionais. Dados de saúde são sensíveis pela LGPD e uma perda pode ser irreversível.

Prioridade 2º: crítico, mas abaixo do R2, que já ocorre repetidamente. Também é a última linha de defesa contra o R3.

5.2 R2 – LENTIDÃO/QUEDA DO PRONTUÁRIO (ÍNDICE 25)

Probabilidade 5: o evento já ocorre repetidamente: 7 dos últimos 20 dias úteis (35% dos dias), com 146 chamados.

Impacto 5: interrompe o atendimento em 4 unidades de saúde e 1 hospital e pode comprometer a segurança do paciente.

Prioridade 1º: maior índice da matriz (25) e atinge a saúde, prioridade institucional.

5.3 R3 – MALWARE VIA COMPUTADORES DESATUALIZADOS (ÍNDICE 12)

Probabilidade 3: a vulnerabilidade existe em 14 máquinas, mas o diagnóstico não registra incidente de segurança até agora.

Impacto 4: um ataque pode se espalhar pela rede e atingir sistemas essenciais. Sobe para 5 se os 14 computadores estiverem na saúde ou na folha (ver seção 8).

Prioridade 3º: empata com o R4 (índice 12), mas pode desencadear o R1, que atinge folha e saúde, prioridades institucionais; o R4 não atinge nenhuma das duas.

5.4 R4 – INDISPONIBILIDADE DO PORTAL (ÍNDICE 12)

Probabilidade 4: o portal ficou 19 horas fora do ar no último mês e nada mudou desde então (sem SLA nem procedimento de continuidade).

Impacto 3: afeta cerca de 4.000 acessos mensais, mas só 18% dos serviços são totalmente on-line; o cidadão ainda tem o atendimento presencial como alternativa.

Prioridade 4º: não atinge saúde nem folha.

6 RESPOSTA AO RISCO

Os quatro riscos serão tratados com a estratégia reduzir, com ações verificáveis dentro do primeiro ciclo de 12 meses, conforme o Quadro 4. Prazos contados a partir de 30/09/2026.

Quadro 4 – Resposta aos riscos

Risco	Controles existentes	Tratamento proposto	Responsável	Prazo	Evidência
R1	Corretivo: backup parcial (parte manual); um teste de restauração realizado há 11 meses. Não há teste periódico.	**Reduzir.** Realizar teste de restauração da folha e do prontuário já no primeiro mês. Automatizar o backup desses sistemas, com cópia fora do ambiente principal. Instituir teste mensal de restauração documentado.	Coordenação de TI (execução), com Sec. de Administração e Sec. de Saúde validando os dados restaurados	1º teste até 30/10/2026; backup automatizado até 31/12/2026; testes mensais até 30/09/2027	Relatório mensal de teste (data, sistema, tempo de recuperação, resultado); logs de execução automática. Meta do PDTI: 100% dos testes realizados em até 12 meses.
R2	Detectivo: registro de chamados (146 abertos). Não há controle preventivo nem tratamento da causa.	**Reduzir.** Analisar os 146 chamados por unidade, horário e tipo para achar a causa raiz. Corrigir a causa (rede, servidor ou fornecedor). Exigir SLA de desempenho do fornecedor, se o sistema for contratado. Padronizar um procedimento de contingência para registro durante falhas.	Gestor de Sistemas, com a Secretaria de Saúde	Análise até 30/10/2026; plano de correção até 30/11/2026; SLA até 31/12/2026	Relatório de causa raiz; contagem mensal de dias com lentidão e de chamados sobre o prontuário (redução em relação a 7 dias e 146 chamados); cláusula de SLA no contrato.
R3	Preventivo: os demais computadores recebem atualizações; os 14 citados estão fora desse processo.	**Reduzir.** Fazer inventário dos 38 computadores antigos com setor e situação de atualização. Atualizar os que suportarem; isolar da rede ou retirar de uso os que não suportarem. Incluir a substituição no PDTI, com aprovação do Gabinete e da Sec. de Administração se for de alto custo.	Coordenação de TI (técnico); Secretaria de Administração (aquisição)	Inventário até 30/10/2026; os 14 tratados até 30/11/2026; plano de substituição até 31/03/2027	Inventário de ativos atualizado; relatório mostrando 0 computador sem atualização ligado à rede; processo de aquisição aprovado.
R4	Ausente: não há SLA nem procedimento de continuidade (controle preventivo e corretivo).	**Reduzir.** Implantar monitoramento de disponibilidade com alerta à equipe. Elaborar procedimento de continuidade do portal (quem aciona, passos de recuperação, aviso ao cidadão). Incluir SLA de disponibilidade no contrato de hospedagem, se terceirizado.	Gestor de Sistemas, com a Coordenação de TI	Monitoramento até 30/10/2026; procedimento até 30/11/2026; SLA até 31/03/2027	Relatório mensal de disponibilidade (meta do PDTI: ≥ 99% ao mês); procedimento aprovado; registro de incidentes do portal.

Fonte: elaborado pelos autores (2026).

7 RELAÇÃO COM O PDTI E A PSI

Dois riscos reforçam linhas já existentes no PDTI do trio; dois indicam linhas que o PDTI ainda não cobre. Na Política de Segurança da Informação (PSI) da Equipe 03, três riscos têm diretriz correspondente e um não tem. A relação está no Quadro 5.

Quadro 5 – Relação dos riscos com o PDTI e a PSI

Risco	PDTI (Matriz Inicial do trio)	PSI
R1	Linha 1 – Integridade de dados: rotina de backup automatizado; meta de 100% dos testes em até 12 meses.	P3 (seção 6) – Backup 3-2-1 automatizado, com notificação de falhas e teste formal de restauração mensal (o primeiro até o mês 4).
R2	Não há linha específica; propor nova linha para o prontuário, já que saúde é prioridade institucional.	P2 (seção 6) – Gestão de mudanças e desempenho do prontuário: mudanças testadas antes da implantação e com previsão de reversão. Complementada pela seção 5: tráfego do prontuário com prioridade na rede das Unidades Básicas de Saúde (UBS), por qualidade de serviço (QoS).
R3	Não há linha específica; propor linha de atualização e renovação do parque de computadores.	Não há diretriz específica na PSI; propor inclusão de diretriz sobre atualização de segurança e proteção contra código malicioso.
R4	Linha 2 – Disponibilidade do portal e serviços digitais; meta de disponibilidade ≥ 99% ao mês.	P1 (seção 6) – SLA formal, monitoramento contínuo e plano de recuperação do portal, com meta de restauração em até 4 horas.

Fonte: elaborado pelos autores (2026).

8 PENDÊNCIAS

As informações do Quadro 6 não constam no cenário e não foram presumidas. Cada uma indica como deve ser confirmada.

Quadro 6 – Pendências que dependem de confirmação

Pendência	**Risco**	**Como confirmar**
Onde ficam as cópias de backup e se há cópia fora do prédio	R1	Levantamento com a Coordenação de TI.
Tempo máximo aceitável de parada e de perda de dados da folha e do prontuário	R1, R2	Reunião com a Secretaria de Administração e a Secretaria de Saúde.
Se o prontuário é sistema próprio ou contratado (um dos 23 contratos)	R2	Verificar contratos com a Secretaria de Administração.
Em quais setores estão os 14 computadores sem atualização	R3	Inventário da Coordenação de TI; se estiverem na saúde ou na folha, o impacto sobe para 5 e o índice para 15 (Alto).
Se existe antivírus ou outra proteção nas estações	R3	Levantamento com a Coordenação de TI; se existir, registrar como controle preventivo existente.
Causa da queda de 19 horas do portal e se a hospedagem é própria ou contratada	R4	Registro do incidente e contratos, com o Gestor de Sistemas.
Inexistência de Comitê de Governança de TI para aprovar e acompanhar os tratamentos	Todos	Propor ao Gabinete a criação do comitê, conforme recomendação da Controladoria.

Fonte: elaborado pelos autores (2026).